



26T2-SEC-RM-001

User Application Hardening Control Mapping

Contents

1. Essential Eight User Application Hardening	2
1.1 Project Context & Workstream Focus.....	2
1.2 Scope & Maturity Level Targeting	2
1.3 Core ML1 Compliance Requirements	3
2. How Intune Enforces User Application Hardening	3
3. ML1 Controls	4
3.1 E8-UAH-1.1 Internet Explorer 11 is Disabled or Removed.....	4
3.2 E8-UAH-1.2 Web Browsers Do Not Process Java from the Internet	4
3.3 E8-UAH-1.3 Web Browsers Do Not Process Web Advertisements	5
3.4 E8-UAH-1.4 Web Browser Security Settings Cannot Be Changed by Users	5
4. Alignment with CIS Microsoft 365 Controls	6
5. Summary Table & Key Findings.....	7
5.1 Summary Table.....	7
5.2 Key Findings.....	7
6. References.....	8

1. Essential Eight User Application Hardening

1.1 Project Context & Workstream Focus

AutoAudit is an automated compliance assessment platform designed to assess Microsoft 365 environments against recognised cybersecurity frameworks. As of Trimester 1, 2026, the platform is a working MVP with a functional backend API, frontend, and engine. Currently, compliance coverage is limited to the CIS Microsoft 365 Foundations Benchmark.

Web Browsers and productivity applications serve as primary attack vectors for external threat actors attempting to execute arbitrary code or conduct drive-by download attacks. User Application Hardening aims to reduce this attack surface by removing legacy, vulnerable application components and restricting web content processing capabilities.

This research serves as a starting point for adding Essential Eight support to AutoAudit, specifically targeting the User Application Hardening Strategy. The objective of this mitigation strategy is to reduce the attack surface of workstations by disabling or removing legacy software (like Internet Explorer 11), and by preventing web browsers from processing high-risk content such as Java and internet advertisements.

1.2 Scope & Maturity Level Targeting

The Essential Eight User Application Hardening mitigation strategy is assessed across four maturity levels (MLs). Each level builds on the preceding ML. In alignment with AutoAudit's agile delivery model, this mapping specification focusses strictly on **Maturity Level 1 (ML1)** to establish baseline cloud assessment capabilities.

<i>Maturity Level</i>	<i>Platform Status & Compliance Meaning</i>	<i>Scope Status & Justification</i>
<i>ML0</i>	No application hardening policies deployed in Intune. AutoAudit infers ML0 by the absence of the required ML1 Intune policies.	Baseline State
<i>ML1</i>	Internet Explorer 11 disabled/removed, Java blocked in browsers, web ads blocked from internet sources, and security settings locked against standard user modification.	In Scope Directly automatable via Intune Settings Catalog policies.
<i>ML2</i>	Expands on ML1 by enforcing Microsoft Defender Attack Surface Reduction (ASR) rules, including blocking Office child processes, executable creation, and code injection.	Out of Scope Shifts focus from Intune Settings Catalog browser policies to Defender for Endpoint Attack Surface Reduction (ASR) rules.
<i>ML3</i>	Extends ML2 by disabling/removing .NET Framework 3.5 and PowerShell 2.0, enforcing Constrained Language Mode, and requiring command-line logging.	Out of Scope Requires host OS-level feature removal scripts, local registry execution, and SIEM event log collectors.

1.3 Core ML1 Compliance Requirements

To achieve ML1 compliance for User Application Hardening, an organisation must enforce four technical objectives across its managed endpoints:

1. **Internet Explorer 11 is disabled or removed.**
2. **Web browsers do not process Java from the internet.**
3. **Web browsers do not process web advertisements from the internet.**
4. **Web browser security settings cannot be changed by users.**

2. How Intune Enforces User Application Hardening

User application hardening in an M365 environment is configured and pushed to devices through Microsoft Intune. What I found during this research is that for Maturity Level 1, the required browser configurations and application restrictions reside exclusively within the modern Settings Catalog. This means the collectors will primarily interact with a single Graph API surface to verify the presence and configuration of these policies, simplifying the backend collection process compared to frameworks that mix legacy and modern endpoints.

<i>Policy Surface</i>	<i>Graph API Endpoint</i>	<i>Used For</i>
<i>Settings Catalog (Modern)</i>	GET /beta/deviceManagement/configurationPolicies	Lists all Settings Catalog policies in the tenant.
<i>Settings Catalog – settings detail</i>	GET /beta/deviceManagement/configurationPolicies/{id}/settings	Reads the actual configured values inside a given policy.

The required Graph API permission for all of these endpoints is `DeviceManagementConfiguration.Read.All`.

Both Settings Catalog endpoints follow the same paging pattern as existing collectors, so there is already a solid template to build from.

Important Note

The ADMX-backed setting IDs used setting by Settings Catalog are verbose and application-specific. There are separate settings IDs for different web browsers (Microsoft Edge or Google Chrome). Furthermore, while legacy application deprecation like Internet Explorer 11 can be executed locally via PowerShell scripts (e.g. `Disable-WindowsOptionalFeature -Online -FeatureName Internet-Explorer-Optional-amd64`), AutoAudit's cloud-based assessment will strictly evaluate the Intune Settings Catalog API response to confirm the restriction is enforced at the tenant level.

3. ML1 Controls

All four ML1 controls sit within the Intune Settings Catalog or rely on OS-level feature management. Each browser configuration can be verified at the policy level, so we can confirm the policy exists and is assigned to the right scope, but we cannot confirm from the API alone that it has applied to every individual managed device. That is the honest limitation of what the checks can tell us, and it maps to ASD's Fair evidence confidence level.

3.1 E8-UAH-1.1 Internet Explorer 11 is Disabled or Removed

This control ensures that Internet Explorer 11 is no longer accessible as a standalone browser. While AutoAudit can check if Intune pushes a deprecation policy, the most definitive removal is at the OS feature level (e.g. executing PowerShell scripts to remove the Internet-Explorer-Optional-amd64 feature entirely.)

<i>Field</i>	<i>Detail</i>
Intune Settings Catalog Path	Administrative Templates → Windows Components → Internet Explorer → Disable Internet Explorer 11 as a standalone browser
Compliant Values	1 (Enabled)
Graph API endpoint	GET /beta/deviceManagement/configurationPolicies/{id}/settings
Setting ID	user_vendor_msft_policy_config_internetexplorer_disableie11
Automatable?	Partially Policy-level check only, cannot confirm per-device application from the API or if a user manually re-enabled the feature.
Confidence	Fair

3.2 E8-UAH-1.2 Web Browsers Do Not Process Java from the Internet

This control checks that web browsers (specifically Microsoft Edge) are configured to block Java execution on untrusted sites. Java plugins are a historical vector for arbitrary code execution.

<i>Field</i>	<i>Detail</i>
Intune Settings Catalog Path	Microsoft Edge → Site Settings → Default Java Setting
Compliant Values	2 (Do not allow any site to run Java)
Graph API endpoint	GET /beta/deviceManagement/configurationPolicies/{id}/settings
Setting ID	user_vendor_msft_policy_config_edge_defaultjavasetting
Automatable?	Partially
Confidence	Fair

3.3 E8-UAH-1.3 Web Browsers Do Not Process Web Advertisements

This control checks that web browsers filter out internet advertisements to prevent “malvertising” attacks. Since Intune does not have a single “block ads” toggle, this is achieved through forcing the silent installation of approved enterprise ad-blocking extensions.

Field	Detail
Intune Settings Catalog Path	Microsoft Edge → Extensions → Control which extensions are installed silently
Compliant Values	List containing the specific Extension IDs for organizational ad-blockers (e.g., uBlock Origin).
Graph API endpoint	GET /beta/deviceManagement/configurationPolicies/{id}/settings
Setting ID	user_vendor_msft_policy_config_edge_extensioninstallforcelist
Automatable?	Partially We can verify the extension ID is pushed but cannot confirm if the extension is actively running or crashing on the endpoint.
Confidence	Fair

3.4 E8-UAH-1.4 Web Browser Security Settings Cannot Be Changed by Users

This control is different from the others since there is no discrete ‘lock’ setting in Intune, instead, enforcing it is indirect. When browser settings are deployed via Intune MDM policy, the policies take precedence over the user registry changes by design on any Intune-enrolled device. We can check via the API whether the hardening policies exist and are assigned with the correct scope.

Field	Detail
Intune Settings Catalog Path	*No discrete lock setting exists* User override prevention is done through configurations that are deployed via Intune MDM policy.
Graph API endpoint	GET /beta/deviceManagement/configurationPolicies Verify whether the policy exists and is assigned to all users or devices with no user-override scope.
Setting ID	N/A Assessed via policy assignment scope, not a specific setting value.
Automatable?	Partially We can verify the policy is assigned broadly, but cannot confirm from the API that a user cannot override the setting at the registry level.
Confidence	Fair

4. Alignment with CIS Microsoft 365 Controls

Within AutoAudit, the current compliance coverage is limited to the CIS Microsoft 365 Foundations Benchmark. When mapping the Essential Eight User Application Hardening requirements to the existing CIS controls, a significant scope divergence is apparent.

The CIS Microsoft 365 Foundations Benchmark provides technical configuration guidance for cloud services, specifically focusing on the Microsoft 365 Cloud offerings. However, it scopes out local endpoint software configurations, noting that “the individual software applications installed on the end user device: Word, Excel, etc. are covered in separate benchmarks that complement this guide”.

Because the CIS Microsoft 365 Benchmark focuses on cloud tenant infrastructure rather than the endpoint applications, there are no existing CIS controls within the AutoAudit platform that directly overlap with the Essential Eight User Application Hardening requirements for web browsers. Implementing this Essential Eight control therefore represents a new compliance capability for AutoAudit, bridging the gap between cloud tenant governance and endpoint browser security.

Area	Essential Eight (User Application Hardening)	CIS M365 Foundations Benchmark (AutoAudit)
Primary Focus	Endpoint application surface reduction (Browsers, IE11, Java, Ads).	Cloud tenant infrastructure and identity security.
Scope	Individual software applications installed on end-user devices.	Microsoft 365 Cloud offerings running on any OS.
Implementation Guidance	Defines the security outcomes to be achieved on the endpoint.	Defines technical controls and governance mechanisms for the cloud tenant.
Assessment basis in AutoAudit	Proposed assessment using Intune Settings Catalog device configuration policies.	Existing Rego rules evaluating Entra ID, Exchange, and Purview configurations.

5. Summary Table & Key Findings

5.1 Summary Table

The full picture across all four controls for Maturity Level 1 detailing the Intune scope, the API endpoint to use, and what AutoAudit can realistically check.

Control	Description	ML	Graph API Endpoint	Auto?	Confidence
None	No controls implemented	ML0	N/A	N/A	N/A
E8-UAH-1.1	Internet Explorer 11 disabled or removed	ML1	/beta/deviceManagement/configurationPolicies/{id}/settings	Partially	Fair
E8-UAH-1.2	Internet-sourced Java blocked	ML1	/beta/deviceManagement/configurationPolicies/{id}/settings	Partially	Fair
E8-UAH-1.3	Web advertisements blocked	ML1	/beta/deviceManagement/configurationPolicies/{id}/settings	Partially	Fair
E8-UAH-1.4	Users cannot change browser settings	ML1	/beta/deviceManagement/configurationPolicies (assignment check)	Partially	Fair

5.2 Key Findings

1. ML0 Is the Default Starting Point

If none of the ML1 policies exist or are assigned in Intune, AutoAudit should classify the organisation as ML0. There is no dedicated API call for this as it is implied by the absence of ML1 browser hardening policies. This is important to handle explicitly so that the organisations with no controls configured do not simply show as “Unknown”.

2. ‘Partial’ Has Specific Meaning and Should Be Communicated Clearly

For all ML1 controls, AutoAudit can verify the Intune policy exists and is assigned to the right scope. What it cannot verify is via the Graph API is whether that policy has actually been applied successfully to every managed device. This is mapped to ASD’s Fair evidence confidence level and should be clearly labelled in AutoAudit’s output. Therefore, an organisation seeing a ‘pass’ needs to understand it represents a policy-level pass, not a device-level guarantee.

3. A New Intune Collector Is Needed

There is (at the time of writing this report) no AutoAudit collector for the deviceManagement/configurationPolicies endpoint (the Intune Settings Catalog). Until this is built, none of the Settings Catalog-based controls can be automated. The new collector should pull settings detail and return a structured output for all policies. This requires the

DeviceManagementConfiguration.Read.All permission. To resolve this technical blocker, the GRC team will handle the internal implementation of this collector to enable full automation.

4. The CIS Benchmark leaves an Endpoint Gap

Because the CIS Microsoft 365 Foundations Benchmark strictly targets cloud tenant infrastructure, it deliberately excludes endpoint application hardening. By implementing these Intune Settings Catalog checks, AutoAudit gains a new capability that bridges the gap between cloud configuration and endpoint browser security.

6. References

Australian Signals Directorate. Essential Eight Maturity Model. <https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/essential-eight/essential-eight-maturity-model>

Australian Cyber Security Centre (ACSC). Essential Eight assessment process guide. <https://www.cyber.gov.au/business-government/asds-cyber-security-frameworks/essential-eight/essential-eight-assessment-process-guide>

Microsoft. Intune Settings Catalog overview. Microsoft Learn. <https://learn.microsoft.com/en-us/mem/intune/configuration/settings-catalog>

Microsoft. Graph API deviceManagementConfigurationPolicy. <https://learn.microsoft.com/en-us/graph/api/resources/intune-deviceconfigv2-devicemanagementconfigurationpolicy?view=graph-rest-beta>

Center for Internet Security (CIS). CIS Microsoft 365 Foundations Benchmark. https://www.cisecurity.org/benchmark/microsoft_365

Open Policy Agent. The Rego Policy Language. <https://www.openpolicyagent.org/docs/latest/policy-language/>